Pix Antifraude - Bootcamp QI Tech 2026

Integrantes: Vinícius Guimarães Drexler e Wallace Dametto Teixeira.

O serviço analisa cada Pix válido, grava o pedido e sua decisão e permite consultar o resultado pelo ID informado. As respostas são `approved`, `two_factor_required` ou `rejected`. A política vigente é `pix-score-v9`.

Política de decisão e negociação

Negociação significa aplicar condições previamente definidas para aprovar, solicitar confirmação, rejeitar ou atenuar um sinal. O operador define a política; o cliente não escolhe pesos nem negocia limites no pedido.

Decisão	Significado
`approved`	Nenhum controle exige intervenção adicional.
`two_factor_required`	A operação exige autenticação adicional antes de prosseguir no integrador.
`rejected`	Um limite forte ou uma combinação suficiente de riscos impede a aprovação.

A API decide e registra; não executa autenticação, liquidação ou envio de avisos ao banco. Aprovação local não comprova pagamento ou legitimidade. Os scores são indicadores do protótipo, de 0 a 100, sem significado de probabilidade de fraude.

Como a decisão é formada

Todas as regras são avaliadas. Cada sinal recebe seu peso, ajustado pelo percentual do fator: `piso(pontos da regra × percentual do fator / 100)`. Os percentuais padrão são 100%. Aplica-se o teto de cada fator e limita-se a soma final a 100. Dentro de um fator, os maiores sinais consomem o teto primeiro; o código desempata. Várias regras do mesmo fator continuam sendo um único fator positivo.

Fator	Teto de pontos
Ausência de referência (`exposure`)	80
Frequência e montante (`activity`)	80
Idade da origem (`account`)	15
Destinatário (`counterparty`)	25
Desvio de valor (`profile`)	80
Aparelhos (`device`)	40
Contexto noturno (`access_context`)	15
Duplicidade (`duplication`)	30
Vínculos societários, quando contribuem (`graph`)	20

As regras transacionais seguem esta prioridade:

Ordem	Condição	Decisão
1	Limite forte de frequência ou montante.	`rejected`
2	Score ≥80 e pelo menos dois fatores com contribuição positiva.	`rejected`
3	Ausência de referência aprovada com valor ≥R$ 500, ou score ≥30.	`two_factor_required`
4	Demais situações.	`approved`

Um fator isolado com 80 pontos exige 2FA. Limites fortes e confirmação por ausência de referência continuam obrigatórios mesmo com seus pesos zerados. Depois das regras, o acumulado próprio, os vínculos habilitados e o grafo temporal podem agravar a decisão; nenhuma dessas camadas relaxa uma restrição anterior.

As 13 regras transacionais

Os valores do pedido são inteiros e em centavos: `50000` corresponde a R$ 500. As condições abaixo usam os padrões da política configurada.

Regra	Quando se aplica	Pontos / fator
Frequência	Há pelo menos cinco tentativas anteriores do pagador nos últimos 10 minutos; a atual é a sexta.	80 / `activity`, com rejeição obrigatória
Montante	A soma das tentativas do pagador nos últimos 10 minutos, incluindo a atual, atinge R$ 30 mil.	80 / `activity`, com rejeição obrigatória
Primeiro Pix	Não há tentativa anterior nem referência aprovada, e o valor é ≥R$ 500.	30 / `exposure`, com 2FA obrigatório
Referência insuficiente	Há tentativas anteriores, mas nenhuma referência aprovada, e o valor é ≥R$ 500.	30 / `exposure`, com 2FA obrigatório
Origem recente	A conta de origem tem menos de sete dias completos na data do Pix.	15 / `account`
Destino recente	O destino é desconhecido, a conta tem menos de sete dias completos e o valor é ≥R$ 500.	15 / `counterparty`
Destinatário desconhecido	O pagador tem pelo menos três aprovações em 30 dias, o destino é desconhecido e o valor é ≥R$ 500.	15 / `counterparty`
Desvio de perfil	O valor é pelo menos cinco vezes a média das últimas até dez aprovações do pagador, sem corte por dias. Uma aprovação já forma referência; não há piso monetário para este sinal.	80 / `profile`
Aparelho desconhecido	O pagador tem pelo menos três aprovações em 30 dias, o aparelho é desconhecido e o valor é ≥R$ 500.	20 / `device`
Aparelho compartilhado	Pelo menos três titulares distintos usaram o aparelho em 24 horas, incluindo o atual. Contas do mesmo titular contam uma pessoa.	30 / `device`
Múltiplos aparelhos	O pagador usou pelo menos três aparelhos distintos em 24 horas, incluindo o atual, que deve ser desconhecido.	20 / `device`

Regra	Quando se aplica	Pontos / fator
App noturno fora do hábito	Canal app, entre 20h inclusive e 6h exclusive de Brasília; valor ≥R$ 500; pelo menos três aprovações em 30 dias, nenhuma noturna; aparelho ou destino desconhecido.	15 / `access_context`
Possível duplicidade	Mesmas contas de origem e destino, mesmo valor e outro ID; existe tentativa aprovada ou pendente de 2FA nos 120 segundos anteriores, incluindo os limites da janela.	30 / `duplication`

A frequência, o montante e a diversidade de aparelhos contam aprovações, pendências e rejeições. O valor atual entra no montante; o aparelho e o titular atuais entram nas contagens de diversidade. Reenvios do mesmo ID não acrescentam tentativas.

"Conhecido" significa que o pagador teve uma aprovação local com aquele aparelho ou conta destinatária nos últimos 30 dias. Receber um Pix não forma perfil de envio. Pendências e rejeições nunca criam ou elevam a referência de valores.

As janelas transacionais usam a data do Pix e somente informações já recebidas na análise. Eventos futuros ficam fora. A regra noturna ignora maiúsculas e espaços externos do canal; outros canais mantêm os demais controles. Abaixo de R$ 500, ausência de referência não exige confirmação, mas outros sinais podem exigir.

Quando o histórico permite flexibilizar

A confiança contextual pode retirar **somente os pontos do desvio de perfil** quando o valor é habitual naquela relação. Todas estas condições são necessárias:

- Pelo menos cinco aprovações de referência do pagador.
- Pelo menos três aprovações para a mesma conta destinatária.
- Referências da relação recebidas em pelo menos dois dias distintos de Brasília.
- Valor entre 50% e 200% da mediana da relação, com limites inclusivos.

São usadas até 20 aprovações por conjunto, em 30 dias, sem limite forte registrado. Uma rajada de pedidos retrodatados não cria dias distintos de experiência. Referência inválida, insuficiente ou formada por valores incompatíveis não concede a redução. O sinal original e os pontos retirados permanecem na auditoria.

A flexibilização não elimina frequência, montante, aparelho, idade, horário, duplicidade, acumulado ou intervenção do grafo. Familiaridade não concede imunidade.

Suspeita própria acumulada

O `account_untrust` reúne evidências próprias da conta em 24 horas pelo relógio de recebimento do servidor. É separado do `risk_score` da transação e está habilitado por padrão.

Somente frequência, montante, desvio de perfil não atenuado e os três sinais de aparelho podem gerar incremento. Destinatário, ausência de referência, idade, horário, duplicidade, vínculos e GNN não alimentam esse acumulado. Mudar o fator configurável de uma regra não muda a natureza de sua evidência.

Um limite forte elegível acrescenta 25 pontos. Nos demais casos, com score transacional ≥30, o incremento é `mínimo(25, teto(contribuições próprias efetivas / 4))`. Abaixo disso, é zero. Os pontos são calculados antes das camadas relacionais.

Acumulado, incluindo o incremento atual	Consequência
≥40	Exige 2FA, mesmo com `risk_score=0`.
≥60	Também indica aviso ao banco, sem enviá-lo.
≥80 e pelo menos quatro eventos	Pode rejeitar somente se o bloqueio optativo estiver habilitado; o padrão é desligado.

Cada incremento expira individualmente após 24 horas; a exibição é limitada a 100. Histórico já em ≥80 com quatro eventos suspende novos incrementos mesmo com bloqueio desligado, evitando renovar indefinidamente a restrição. Pix de baixo risco não apaga evidências vigentes. Reenvio e entrada inválida não criam incrementos.

Contas, titulares e vínculos societários

A decisão avalia um Pix da origem para o destino. Sinais do destino podem restringir a operação, mas não geram suspeita própria do remetente nem incremento próprio para a conta receptora. A relação é direcional: A→B não cria familiaridade em B→A.

A identidade da conta considera instituição quando informada, agência, número e documento; abertura e aparelho ficam fora. Informar instituição antes omitida pode mudar essa identidade. Trocar aparelho ou abertura não esconde duplicidade.

Frequência, perfil, familiaridade e diversidade agregam contas do mesmo CPF/CNPJ. O acumulado de cada conta permanece separado; a camada do titular pode reunir seus incrementos próprios entre contas. As mesmas regras se aplicam às combinações CPF/CPF, CPF/CNPJ, CNPJ/CPF e CNPJ/CNPJ, sem fundir CPF e CNPJ distintos.

Vínculos societários dependem de cadastro verificado do operador. Transferências, nomes semelhantes ou aparelhos compartilhados não comprovam sociedade. O cadastro inicial é vazio e não há consulta automática à Receita Federal ou ao QSA.

Papel no vínculo	Peso
Controlador ou beneficiário final	1
Administrador	0,5
Minoritário	0,2
Contador	0

A busca respeita conhecimento e validade temporal, até três arestas societárias e 100 entidades. Papéis fracos não fazem ponte entre empresas. O vínculo com a empresa de uma ocorrência precisa ser compatível com a época do incidente. Incidentes são deduplicados, filiais contam uma raiz e ciclos não multiplicam evidências. Ocorrências confirmadas valem até expiração ou revogação explícita.

A exposição é o maior entre: maior severidade ponderada mais corroboração; e metade do maior acumulado relacionado ponderado. Corroboração acrescenta cinco por incidente forte adicional, até 20; forte exige severidade ≥60 e peso de caminho ≥0,75. A exposição é limitada a 100. Empresas limpas não diluem a maior evidência. Uma empresa nova pode ter exposição por seu controlador sem receber ocorrências próprias. Busca truncada não produz inferência relacional parcial.

No padrão `entity_risk=shadow`, esses indicadores não alteram a decisão. Em `contribute`, acrescentam `teto(exposição × 20 / 100)`, ajustado pelo percentual do fator `graph` e limitado a 20. Esses pontos podem

participar da rejeição geral por score. A intervenção direta pede somente 2FA quando há:

- Acumulado próprio do titular ≥40, com esse controle habilitado.
- Ocorrência confirmada própria com severidade ≥60.
- Pelo menos dois incidentes fortes e exposição ≥60.

Peso `graph=0` desativa pontos e intervenção por vínculos, preservando o controle próprio agregado. Nenhuma contribuição relacional gera novos incrementos próprios.

Contribuição do grafo temporal

O padrão `GNN_V2_MODE=contribute` permite elevar somente uma aprovação para `two_factor_required` quando o score do grafo é ≥75,0977 e modelo/política correspondem ao manifesto avaliado. Em `shadow`, observa; em `off`, fica desligado.

O grafo considera direção e tempo dos pagamentos, aparelhos, titulares, evidência própria e repasses rápidos. Repasse é uma saída após uma entrada em até 30 minutos, entre 80% e 125% do recebido, para destino diferente do remetente; uma entrada suporta no máximo um par. O indicador isolado não é uma regra de rejeição.

A análise usa até dois saltos, 300 eventos em 30 dias, 100 documentos e 300 incrementos próprios em 24 horas; exige pelo menos três eventos não rejeitados. Histórico insuficiente, inválido ou truncado e falha tratada de inferência geram abstenção. Modelo ou manifesto incompatíveis impedem a contribuição. Erro de consulta ao banco segue o tratamento de falha, sem aprovação silenciosa.

O grafo não soma pontos ao `risk_score`, não rejeita sozinho, não remove restrições e não gera incremento próprio ou aviso bancário. Score baixo não concede confiança. Seu resultado público é `untrust_score`, quando disponível; é diferente do acumulado da conta e do fator societário `graph`. O modelo usa dados sintéticos.

Exemplos de decisão

Os exemplos pressupõem ausência de outros controles ativos e histórico elegível.

Situação	Score	Decisão
Primeiro Pix de R$ 499,99, contas antigas	0	`approved`
Primeiro Pix de R$ 500, contas antigas	30	`two_factor_required`
Aparelho desconhecido isolado	20	`approved`
Aparelho e destinatário desconhecidos	35	`two_factor_required`
Desvio de perfil isolado	80	`two_factor_required`
Desvio de perfil e origem recente	95	`rejected`
Pix sem sinais atuais, acumulado próprio ≥40	0	`two_factor_required`
Pix aprovado pelas regras, grafo elegível acima do corte	Sem alteração	`two_factor_required`

Registro e consulta de cada Pix

Todo Pix válido com ID inédito é gravado no PostgreSQL, seja aprovado, pendente de 2FA ou rejeitado. Pedido normalizado, decisão, regras, valores usados e política ficam na mesma transação. A resposta de sucesso só ocorre depois do commit.

`POST /pix/transaction` analisa e registra. `GET /pix/transaction/{id}` recupera a decisão gravada. Mesmo ID e conteúdo normalizado devolvem o mesmo resultado, sem nova tentativa; conteúdo diferente gera 409 sem sobrescrever. ID inexistente gera 404. Alterar política, modo ou cadastro não recalcula decisões já salvas.

A resposta contém `key`, `status` e `metadata` com `risk_score` e `bank_notification_required`; o score do grafo aparece quando disponível. `include_details=true` acrescenta somente os nomes das regras aplicadas. A evidência completa permanece no banco.

Campos inválidos geram 400 e não consomem o ID. O pedido exige valor inteiro positivo, documentos CPF/CNPJ completos, datas com fuso, abertura não posterior ao Pix e participante de destino com oito dígitos. Documentos são normalizados sem validação dos dígitos verificadores. IP válido é obrigatório; geolocalização é opcional. IP e coordenadas são armazenados sem pontuar; não há cálculo de distância ou velocidade de deslocamento.

Travas por ID, pagador e aparelho protegem reenvios e tentativas concorrentes. Falha de banco retorna 503; repita o mesmo ID para recuperar eventual decisão confirmada. O volume persiste ao recriar os serviços. Não use `down --volumes` se precisar manter o histórico.

Executar e consultar

Com Docker e Docker Compose, execute na raiz:

```
docker compose up --build
```

Abra o Swagger para enviar e consultar Pix. O exemplo contém R$ 1.500 e, em uma base sem histórico, exige 2FA por ausência de referência. Em PowerShell:

```
$pix = Get-Content -Raw examples/pix.json
Invoke-RestMethod -Method Post -Uri 'http://127.0.0.1:8000/pix/transaction?include_details=true' -ContentType
'application/json' -Body $pix
Invoke-RestMethod -Uri 'http://127.0.0.1:8000/pix/transaction/pix-000123?include_details=true'
```

Use outro ID ao alterar o conteúdo. A política é carregada na inicialização; mudanças do operador valem para novas análises. Para atualizar uma base existente, aplique as migrações pendentes em vez de apagar seu volume.